

SAT 3812: Cyber Security I

Access Control and Password
Management

Instructor: Yunlong Xing



Learning Objectives

- Understand basic access control terminology including ACL, MAC, DAC, RBAC, Auditing, two-factor authentication
- Understand common security models including Bell-Lapadula model, Clark-Wilson model, and Chinese Wall model.
- Explain physical security
- Explain common password weaknesses and best practices of managing passwords.
- Describe biometric authentication, including verification and identification.
- Explain security auditing

What's Next?

5.1 Introduction

5.2 Physical Access and Security

5.3 Passwords

5.4 Access Cards and Tokens

5.5 Biometric Authentication

5.6 Cryptographic Authentication

5.7 Authorization

5.8 Auditing

5.9 Central Authentication Servers

5.10 Directory Servers and Identity Management

5.1: Access Control

■ Access Controls

- Firms must limit access to **physical** and **electronic** resources
- Access control is the **policy-driven** control of access to systems, data, and dialogues

■ Cryptography

- Many access control tools use cryptography to some extent
- However, cryptography is only part of what they do and how they work

5.1: Access Control

■ The AAA Protections

- **Authentication**—supplicant sends credentials to verifier to authenticate the supplicant
- **Authorization**—what permissions the authenticated user will have
 - What resources he or she can get to at all
 - What he or she can do with these resources
- **Auditing**—recording what people do in log files
 - Detecting attacks
 - Identifying breakdowns in implementation

User Authentication

- Why is user authentication a security building block of a system?
 - 1st line of defense
 - Basis of access control & user accountability
- What are the 2 steps of Authentication Process?
 - Identification - specify identifier
 - Verification - bind entity (person) and identifier



5.1: Access Control

■ Beyond Passwords

- Passwords used to be sufficiently strong
- This is no longer true thanks to increasing computer speeds available to hackers
- Companies must move to better authentication options

5.1: Access Control

■ Credentials Are Based On

- What you **know** (e.g., a password)
- What you **have** (e.g., an access card)
- What you **are** (e.g., your fingerprint) or
- What you **do** (e.g., speaking a passphrase)

5.1: Access Control

■ Two-Factor Authentication

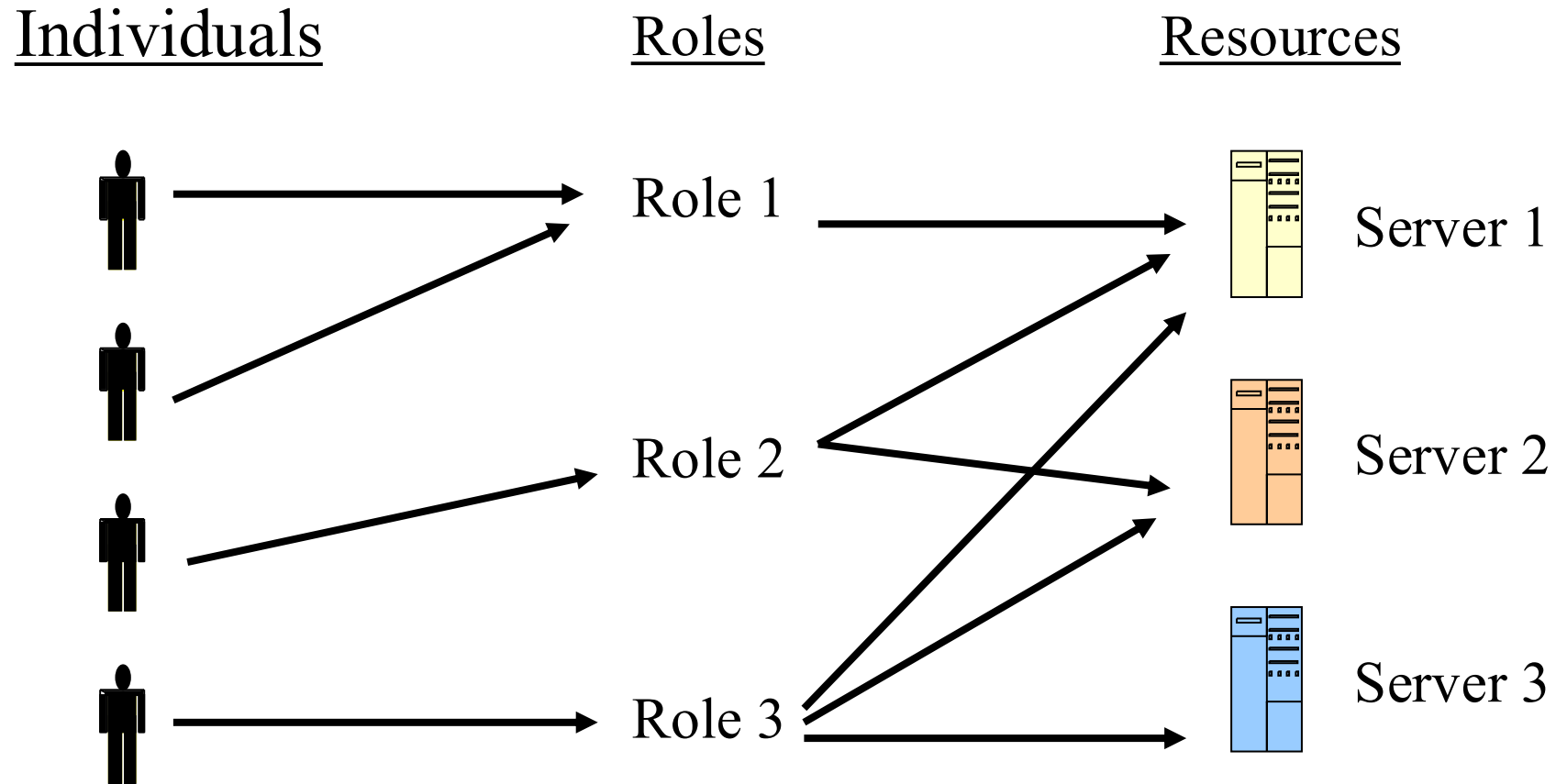
- Use two forms of authentication for defense in depth
- Example: access card and personal identification number (PIN)
- Any other examples?
- Multifactor authentication: two or more types of authentication
- Can be defeated by a Trojan horse on the user's PC
- Can also be defeated by a man-in-the-middle attack by a fake website

5.1: Access Control

■ Individual and Role-Based Access Control

- Individual access control: bases access rules on individual accounts
- Role-based access control (RBAC)
 - Bases access rules on organizational roles (e.g., buyer, member of a team, etc.)
 - Assigns individual accounts to roles to give them access to each role's resources
 - Cheaper and less error-prone than basing access rules on individual accounts
 - Example?

Role-Based AC



Why Role based authentication?

User's change frequently, Roles don't

5.1: Military and National Security Organization Access Controls

■ **Mandatory and Discretionary Access Control**

- **Discretionary access control (DAC)**
 - Departmental or personal ability to alter access control rules set by higher authorities
 - For example, most OSs like windows and Linux
- **Mandatory access control (MAC)**
 - No departmental or personal ability to alter access control rules set by higher authorities
 - For example: military system

Access Control Matrix

- **Subjects** (users) index the rows
- **Objects** (resources) index the columns

	OS	Accounting program	Accounting data	Insurance data	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

Access Control Lists (ACLs)

- ACL: store access control matrix by **column**
- Example: ACL for insurance data is in red

	OS	Accounting program	Accounting data	Insurance data	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

Capabilities (or C-Lists)

- Store access control matrix by **row**
- Example: Capability for **Alice** is in **blue**

	OS	Accounting program	Accounting data	Insurance data	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

5.1: Military and National Security Organization Access Controls

■ **Multilevel Security**

- Resources are classified by security level
 - Public
 - Sensitive but unclassified
 - Secret
 - Top secret
- People are given the same clearance level
- Common in military and government systems

Bell-LaPadula Model: Multi-level Security

- **Bell-LaPadula Model (1973):**
 - *Simple security policy: no read up*
 - a subject at a given security level may not read an object at a higher security level
 - i.e. secret researchers can view public or secret files, but may not view top-secret files
 - *Star *-policy: no write down*
 - a subject at a given security level must not write to any object at a lower security level
 - i.e. secret researchers can create secret or top-secret files but may not create public files
 - Why???
 - The Strong Star Property: subjects may write to objects with only a matching security level

Yellow Tag Question

- Suppose you have a secure system with two subjects and two objects. Notation H is High security level, and L is Low security level.

Type	Name	Level
Object	Obj1	H
	Obj2	L
Subject	Subj1	L
	Subj2	H

- You wish to implement a Bell and LaPadula model of security for this system. Fill in the access rights (R and/or W) permitted by the model for each subject/object pair in the access matrix below.

	Obj1	Obj2
Subj1		
Subj2		

Biba Model

- Biba integrity model: deals with integrity rather than confidentiality. It's "BLP upside down" – high integrity data mustn't be contaminated with lower integrity stuff
 - To remember the purpose of the Biba model, just keep in mind that the "i" in Biba stands for integrity.
- Each subject and object in the system is assigned an integrity classification
 - Crucial
 - Important
 - Unknown
- Example: medical device: calibration data vs operation data

Two principles

- **No-read-down**: A subject is allowed a read access to an object only if the access class of the object dominates the access class of the subject
- **No-write-up**: A subject is allowed a write access to an object only if the access class of the subject is dominated by the access class of the object

Another Example on Biba Model

After a long journey on your search for Shangri-La and true security awareness, you arrive at a Tibetan monastery. You discover the monks are huge fans of the Biba model and as such, have defined certain rules that you, the commoner, must abide by.

- A Tibetan monk may write a prayer book that can be read by commoners, but not one to be read by a high priest.
- A Tibetan monk may read a book written by the high priest, but may not read down to a pamphlet written by a commoner.

Consider this story when you are trying to conceptualize the Biba model and it might make the task a little easier. A final tip is to look at the * star property for both the Bell-LaPadula model and the Biba model. Notice how both deal with write.

Clark-Wilson Model

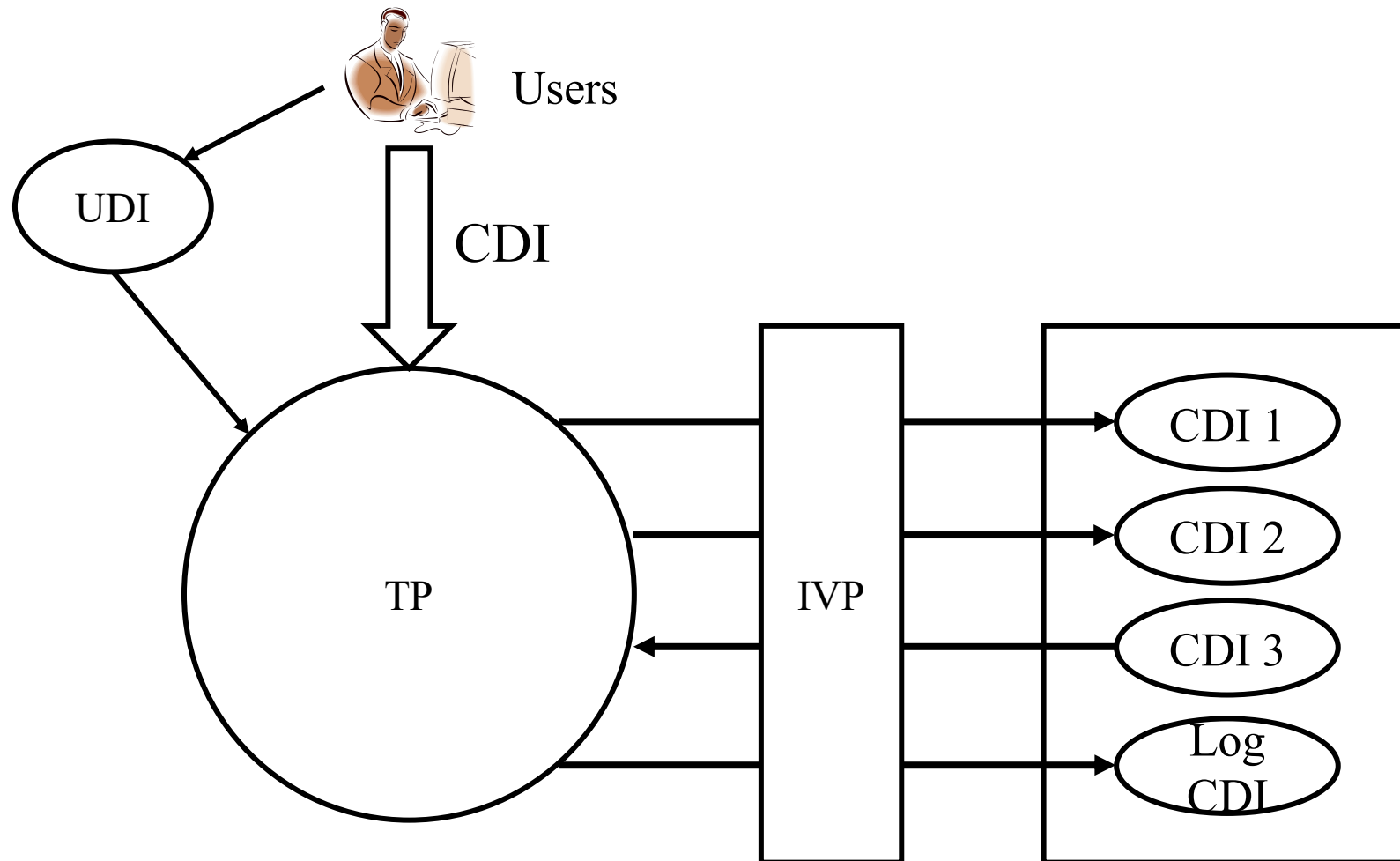
- Developed by Clark-Wilson in 1987, the model addresses the **integrity** requirements of applications.
- Clark-Wilson model enforces the three goals of integrity by using **access triple** (subject, software TP, and object), **separation of duties**, and **auditing**. It enforces integrity by using well-formed transactions (through access triple) and separation of user duties.
- Banking or accounting models

Clark-Wilson Model Concepts

The model uses the following elements:

- **Users:** Active agents.
- **Transformation Procedures** (TPs): Programed abstract operations, such as read, write and modify.
- **Constrained Data Item** (CDI): A data item whose integrity is to be preserved. Can only be manipulated by TPs.
- **Unconstrained Data Item** (UDI): Data items outside of the control area of the modeled environment such as input information. Can be manipulated by users via primitive read and write operations.
- **Integrity Verification Procedure** (IVP): Check the consistency of CDIs with external reality.

Clark-Wilson Model



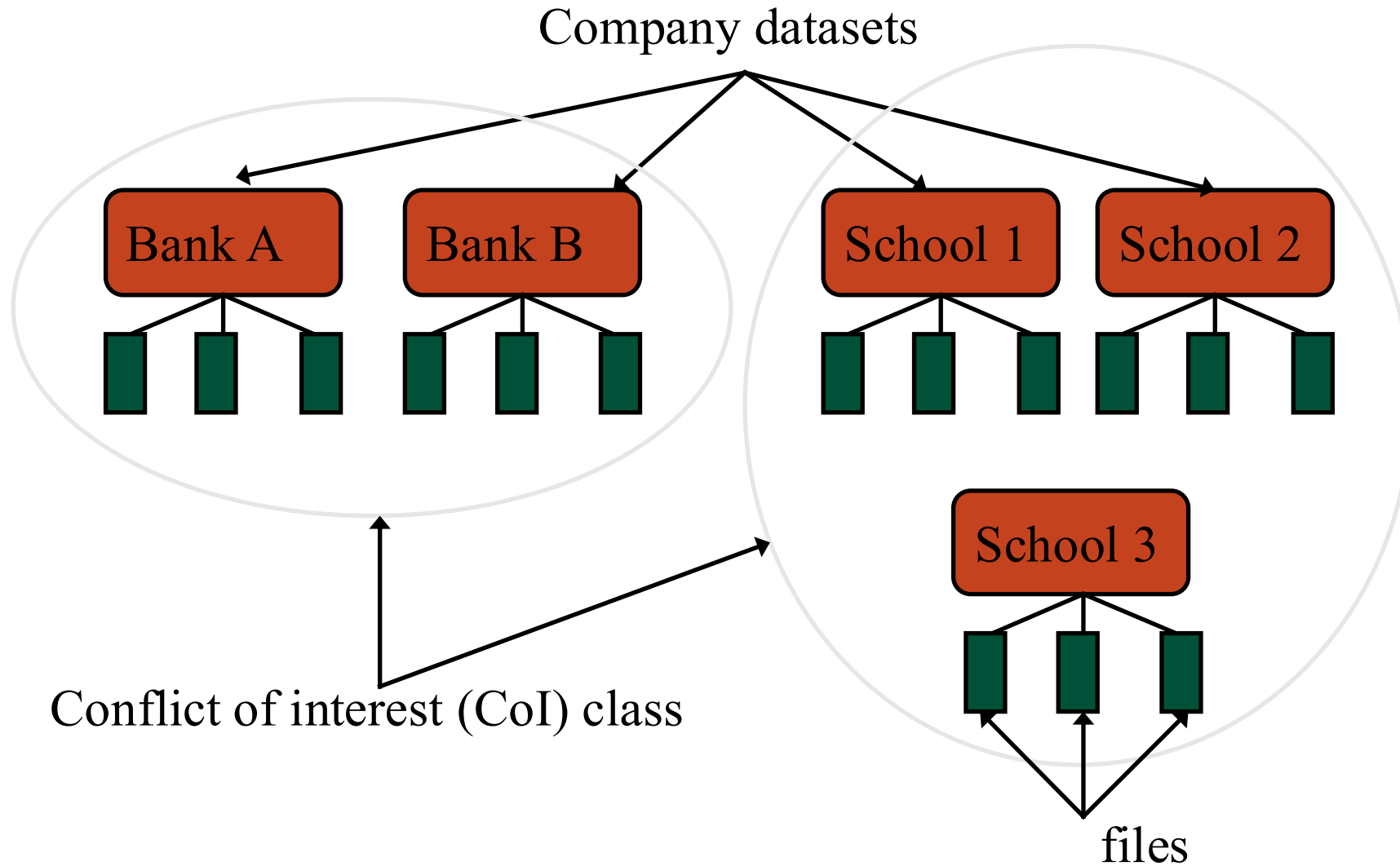
Clark-Wilson Model Example

- Banking or accounting business
 - CDI: account
 - UDI: other less important data
 - TP: credit or debit action to an account
 - IVP: auditor / monitor
- Mental model: a TP in a bank must increase the balance in one CDI (account) by the same amount that it decrements another

The Chinese Wall Model

- Also called **Brewer Nash model**.
- Intended to **prevent conflicts of interest**
- Objects are grouped into ***datasets*** (e.g., all files associated with some client)
- Datasets are grouped into ***conflict-of-interest (Col) classes***
 - For example, consider the following conflict classes:
 - { Ford, Chrysler, GM }
 - { Bank of America, Wells Fargo, Citicorp }
 - { BP, Shell }
- Access rights are dynamically updated based on actions of the subjects

Chinese wall -- basic setup



Chinese wall rules I

- Subject S is allowed to **read** from *at most one* company dataset **in any Col class**
 - This rule is dynamically updated as accesses occur
 - For example, if you access a file from GM, you subsequently will be blocked from accessing any files from Ford or Chrysler. You are free to access files from companies in any other conflict class.

Chinese wall rules II

- S can write to dataset X only if
 - S can only read from dataset X
- This means: either S cannot write at all, or can only write to one dataset
- Why? This is intended to prevent an indirect flow of information that would cause a conflict of interest
 - E.g., S1 reads from BP and writes to Citi; S2 can read from Shell and Citi.
 - S2 may find out information about BP and Shell.

Example of Chinese Wall Model

- 1966, Merrill Lynch was the underwriter of convertible bonds for Douglas Inc.
- Douglas will release a bad earning report.
- A ML staff got the information from another ML staff in a different department.
- The information was leaked to a few institutional customers.
- ML settled the case with fine and compensation, and built mechanisms to stop insider trading.

In-class Study Question: Suppose you work for a company with a Chinese Wall security policy with clients in the following conflict classes:

{ Cadbury, Nestle }

{ Ford, Chrysler, GM }

{ Citicorp, Credit Lyonnais, Deutsche Bank }

{ Microsoft }

You have previously worked on cases for Ford and Citicorp, and you are ready for a new assignment.

List any of your company's clients for whom you *are not* able to work as your next assignment.

What's Next?

5.1 Introduction

5.2 Physical Access and Security

5.3 Passwords

5.4 Access Cards and Tokens

5.5 Biometric Authentication

5.6 Cryptographic Authentication

5.7 Authorization

5.8 Auditing

5.9 Central Authentication Servers

5.10 Directory Servers and Identity Management

5.2: ISO/IEC 27002:2005 Physical and Environmental Security

- **ISO/IEC 27002's Security Clause 9, Physical and Environmental Security**
- **ISO/IEC 9.1: Secure Areas**
 - Securing the building's physical perimeter (e.g., single point of entry, emergency exits, etc.)
 - Implementing physical entry controls
 - Securing public access, delivery, and loading areas
 - Securing offices, rooms, and facilities

5.2: Other Physical Security Issues

■ Monitoring Equipment

- CCTV
- High-resolution cameras are expensive and consume a great deal of disk space
- Low-resolution cameras may be insufficient for recognition needs
- To reduce storage, use motion sensing

Physical Security Issues

- Dumpster Diving
 - Protect building trash bins that may contain sensitive information
 - Maintain trash inside the corporate premises and monitor until removed
- Desktop PC Security
 - Locks that connect the computer to an immovable object
 - Login screens with strong passwords

Password Management

How this happened?

- A hacker group called OurMine took over Mark Zuckerberg's Twitter, Instagram and Pinterest account.
- The hacker started with Linkedin data breach and password dump on 2012.
- Mark used the same password for his social media accounts.
- It is "dadada".

Information leaking search engine

- Most people are illiterate in cybersecurity, or busy, or lazy:
 - They may use a weak password
 - They are very likely to use the same password or similar passwords across multiple sites
 - They may not change their password for years
 - If any site got hacked, all your passwords may be in jeopardy!
 - The probability of password leaking is very high!

Hacking your password is never easier!

- <https://www.leakedsource.com/main>
 - A website established in 2016
 - You can pay to view people's hashed password from old leaks.
 - The site was down a few months later.
- <https://haveibeenpwned.com/>
 - A similar website allows you to get leaking notifications

Practical Suggestions on Password Management

Poor, Weak Password

- Poor, weak passwords have the following characteristics:
 - The password contains less than 8 characters.
 - The password is a word found in a dictionary (English or foreign)
 - The password is a common usage word.
 - The password is your DoB, pet name, phone number, address...

Strong Password

- Strong passwords have the following characteristics:
 - Contain both **uppercase** and lowercase characters
 - Have **digits** and **special** characters
 - Are **at least 12 alphanumeric characters** long and is a passphrase.
 - Are **not a word** in any language , slang , dialect , jargon.
 - Are **not based on personal information.**

Practical suggestions on password

- Use a story to help you remember the password (**at least 12 characters**).
 - Panda@TX28bamboo
 - First letter of a song/poem/sentence
 - I usually buy milk from Walmart at 1400 townsend drive => lubmfW@1400td
 - Character replacement
 - Kingkong@UP4Snow => Kingk0ng@UP4Sn0w => Kingk0ng@UP4Sn0
- **Avoid same password across multiple sites**
 - Something like this:
 - Panda4@microsoft for Microsoft
 - Panda4@amazon for Amazon
 - You should have at least three different passwords:
 - One for your job account;
 - One for important personal accounts, like bank, email...
 - One for other personal accounts.

Practical suggestions on password

- We all use notes, smartphones, or something to store password.
 - Notes might not be a bad idea...
- Do you really trust password management apps?
 - Something like 1password or LastPass
- For security questions or password reset questions, add special characters to your answers
 - Which foreign countries have you visited?
 - Canada# instead of Canada

Sarah Palin's Email Was Hacked in 2008

■ How?

- Hackers used Yahoo!'s password recovery feature, and then proceeded to fill in the answers using Google and Wikipedia.
 - Enable the password recovery feature of Yahoo (less than 1 minute)
 - Wikipedia and Google to find the info, zip code, and Birthday (about 45 min)
 - Answer the question "where did you meet your spouse?" (a little longer time)
 - Google search for "palin eloped"
 - high school, eventually hit on "Wasilla high"

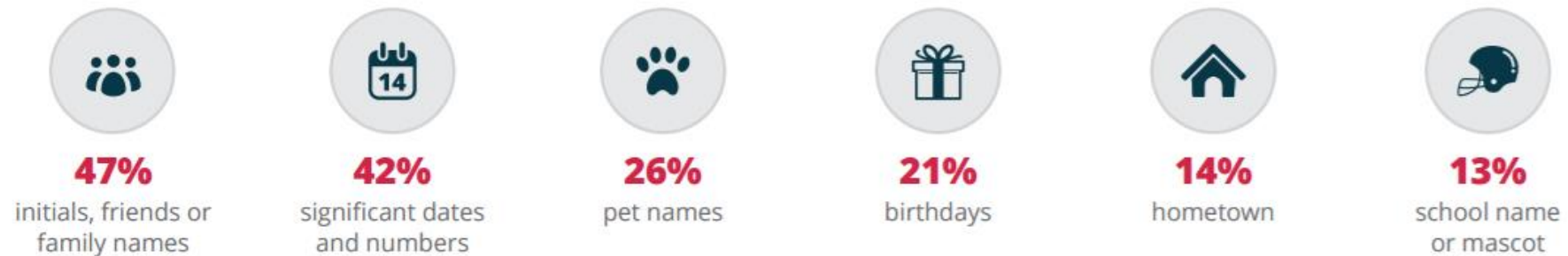
Is password alone enough to protect yourself?

A Report from Lab42

- 91 percent know there is a risk when reusing passwords, but 61 percent continue to do so, and 55 percent do so while fully understanding the risk.
- Only 29 percent of consumers change their passwords for security reasons - the #1 reason people change their passwords is because they forgot it



While users understand what a secure password looks like, they are still falling short when it comes to password creation. A number of users use the criteria below to create their passwords.



COGNITIVE DISSONANCE is the psychological conflict resulting from an individual performing an action that is contradictory to their beliefs, ideas or values.

Source: http://prod.cdata.app.sprinklr.com/DAM/434/LastPass_ExecutiveSummary_fina-88e8a5a2-00cb-4a09-b363-e01a45f829d6-1389898992.pdf

The future of password

- If any site you registered got hacked and leaked, all your passwords may be in jeopardy.
 - if you share passwords across different domains!
 - The probability of password leaking is much higher than your think!
- Password alone is No longer enough to protect yourself!
 - Use two-factor authentication when possible.
- Fix the human firewall!
 - Be educated! Be alert!

How to enable two-factor authentication (2FA)?

- Many websites did provide 2FA, but as a hidden feature which many people don't know how to find it.
 - For example, Gmail,
 - Google "two-factor authentication in Gmail" to get help
- You can do 2FA for Amazon, Facebook, Wells Fargo Bank.....
- 2FA is a bit inconvenient sometimes...
- Some sites don't provide 2FA so far.

The future of password

- Passwords are no longer enough to keep you safe.
- But most organizations are still in the process of phasing out passwords
 - 2FA
 - Access token, security card, USB key...
 - Biometric authentication
 - Other solutions
- The reality: the old system is almost broken, but the new system is not fully ready yet...

What's Next?

5.1 Introduction

5.2 Physical Access and Security

5.3 Passwords

5.4 Access Cards and Tokens

5.5 Biometric Authentication

5.6 Cryptographic Authentication

5.7 Authorization

5.8 Auditing

5.9 Central Authentication Servers

5.10 Directory Servers and Identity Management

5.4: Access Cards and Tokens

■ Access Cards

- Magnetic stripe cards
- Smart cards
 - Have a microprocessor and RAM
 - Can implement public key encryption for challenge/response authentication
- In selection decision, must consider cost and availability of card readers

5.4: Access Cards and Tokens

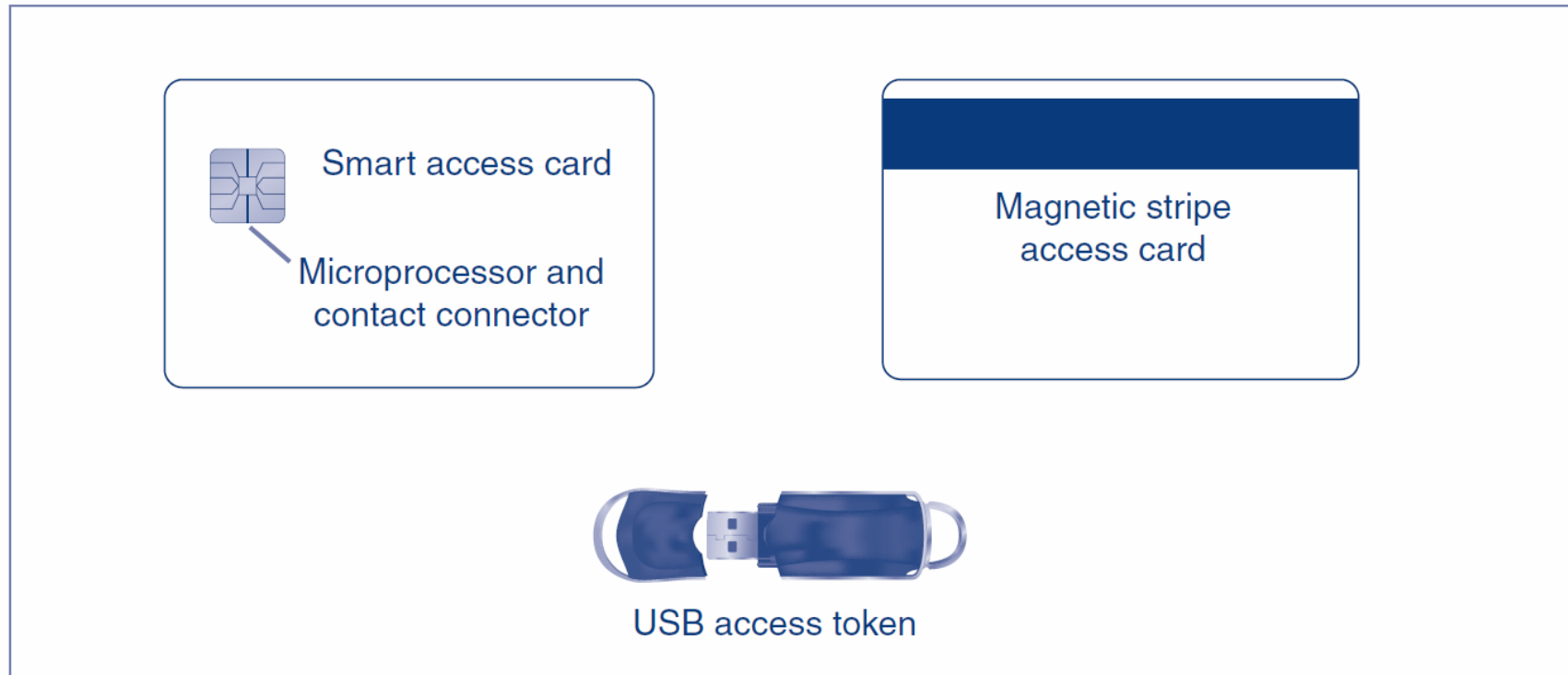
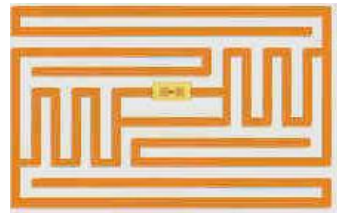


FIGURE 5-8 Access Cards and Tokens

RFID Card

- May become very popular in the near future
- Has two parts
 - One is for storing and processing information, modulating and demodulating a (RF) signal, and other specialized functions.
 - The second is an antenna for receiving and transmitting the signal.
- Authentication with a RFID reader wirelessly



NFC: Near Field Communication

- Short range wireless communication technology between electronic devices
- Used in mobile devices-(Cell phone, PDA)
- Operates at 13.56 MHz
- Devices must be within 4-10 cm of each other
- Faster and easier payments
 - Can replace your wallet
 - Apple Pay?
- Security issues



What's Next?

5.1 Introduction

5.2 Physical Access and Security

5.3 Passwords

5.4 Access Cards and Tokens

5.5 Biometric Authentication

5.6 Cryptographic Authentication

5.7 Authorization

5.8 Auditing

5.9 Central Authentication Servers

5.10 Directory Servers and Identity Management

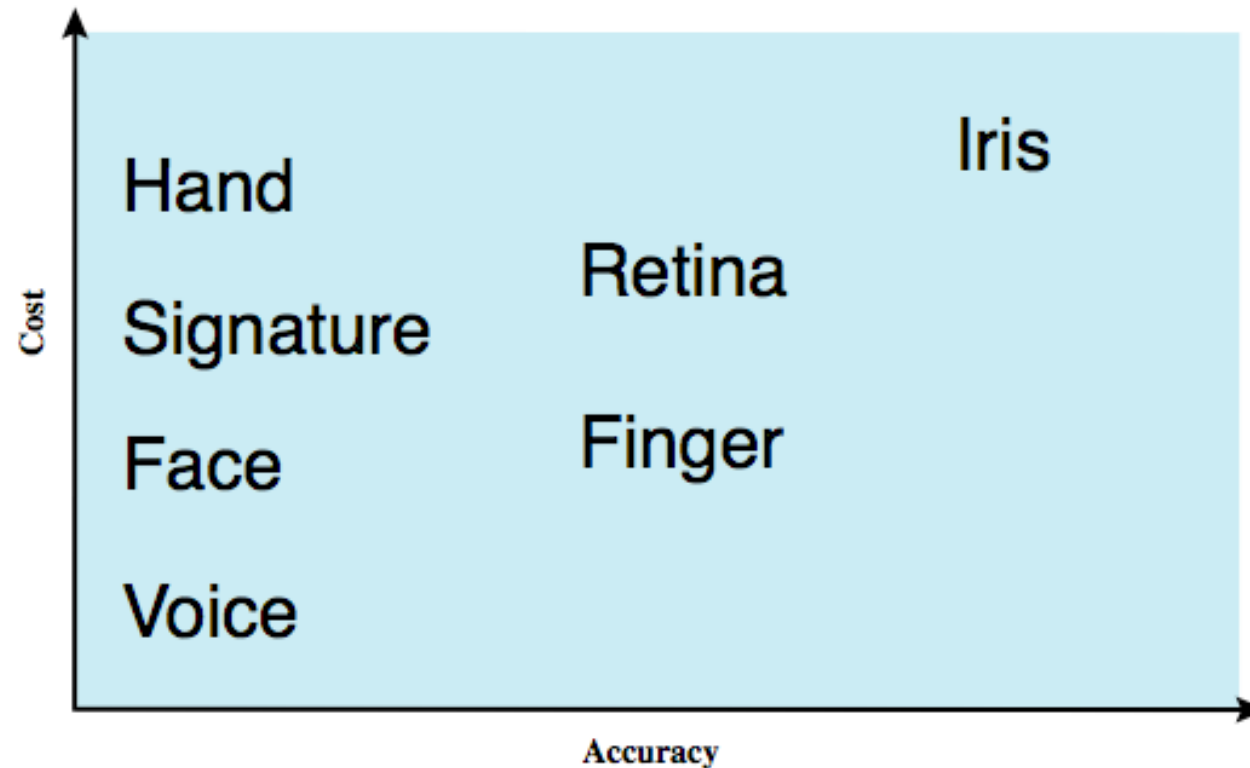
5.5: Biometric Authentication

■ Biometric Authentication

- Authentication based on biological (bio) measurements (metrics)
 - Biometric authentication is based on something you are (e.g., your fingerprint, iris pattern, face, hand geometry, and so forth)
 - Or something you do (e.g., write, type, and so forth)
- The major promise of biometrics is to make reusable passwords obsolete

Biometric Authentication

- More advanced than password or token due to its uniqueness and hard to replicate



5.5: Biometric Authentication

- **Biometric Systems (Figure 5-10)**
 - **Enrollment** (enrollment scan, process for key features, store template)
 - Scan data is variable (scan fingerprint differently each time)
 - Key features extracted from the scan should be nearly the same
 - **Later access** attempts provide access data, which will be turned into key feature data for comparison with the template

5.5: Biometric Authentication System

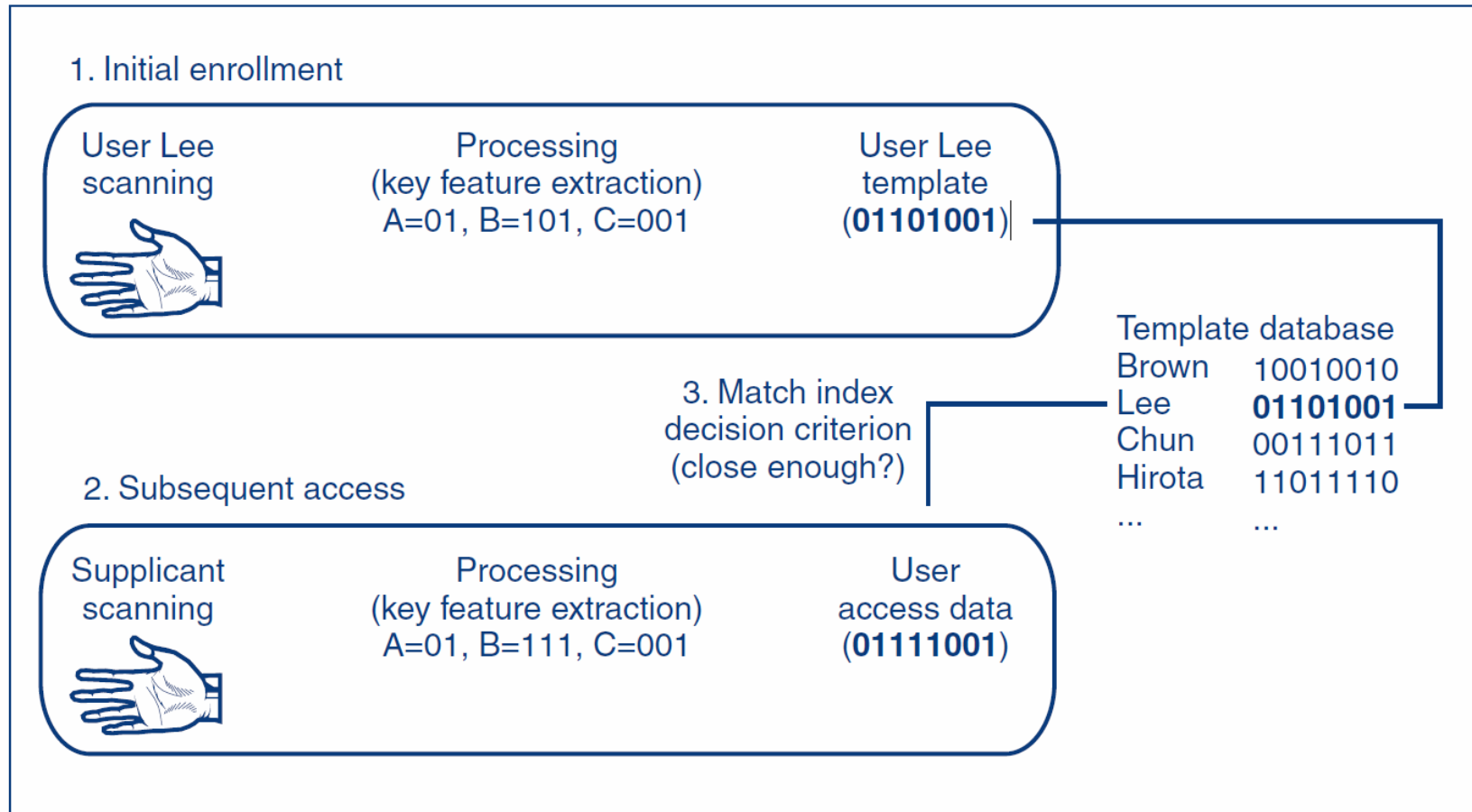


FIGURE 5-10 Biometric Authentication System

5.5: Biometric Errors and Deception

■ False Acceptance Rates (FARs)

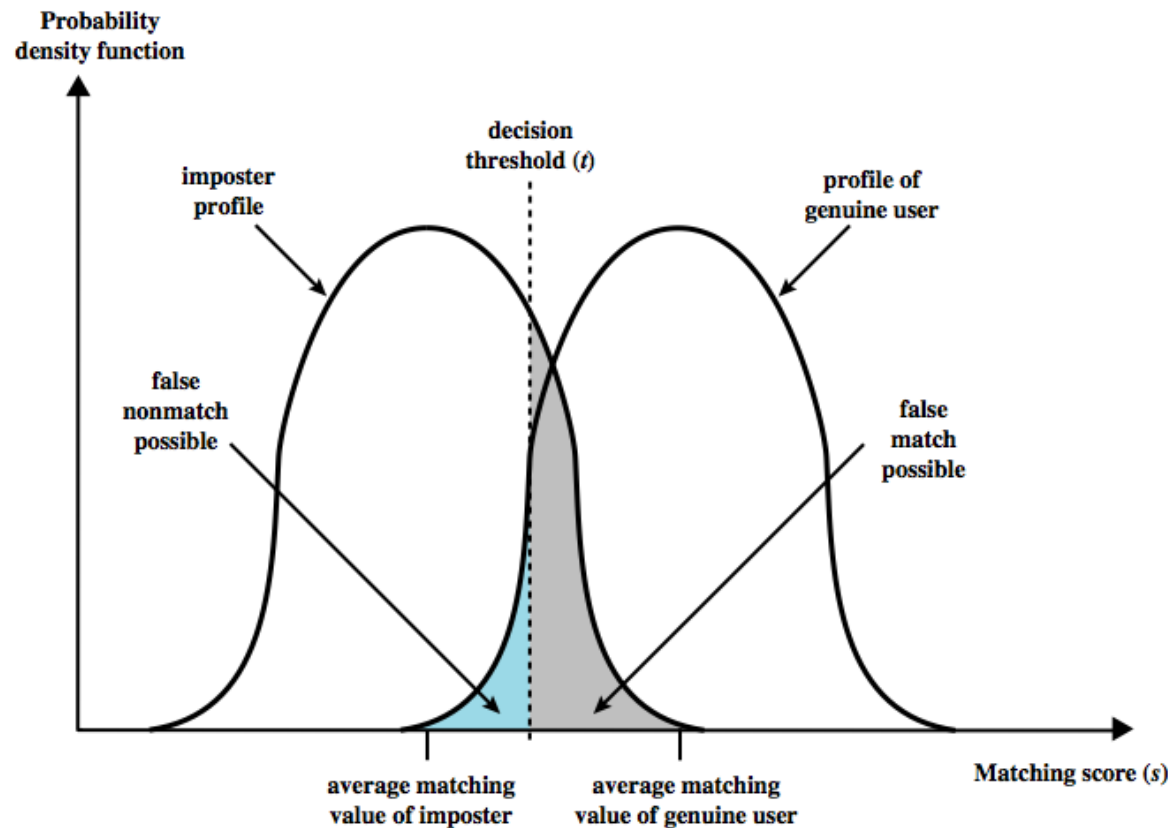
- Percentage of people who are identified or verified as matched to a template but should not be
- Also called False Positive. May cause issues of insulting. Rules are too strict.

■ False Rejection Rates (FRRs)

- Percentage of people who should be identified or verified as matches to a template but are not
- Also called False Negative. May cause issues of safety. Rules are too loose.

Biometric Accuracy

- Need to find a balance point of false positive and false negative



5.5: Biometric Errors and Deception

- **Vendor Claims for FARs and FRRs**
 - Tend to be exaggerated through tests under ideal conditions
- **Failure to Enroll (FTE)**
 - Subject cannot enroll in system
 - E.g., poor fingerprints due to construction work, clerical work, age, etc.

5.5: Biometric Errors and Deception

■ Deception

- Errors: when subject is not trying to fool the system
- Deception: when subject *is* trying to fool the system
 - Hide face from cameras used for face identification
 - Impersonate someone by using a gelatin finger on a fingerprint scanner
 - Etc.

5.5: Biometric Methods

■ Iris Recognition

- Pattern in colored part of eye
- Uses a camera (no light is shined into eye, as in Hollywood movies)
- Very low FARs
- Very expensive

5.5: Biometric Methods

■ Face Recognition

- Surreptitious identification is possible (in airports, etc.)
- Surreptitious means *without the subject's knowledge*
- High error rates, even without deception

■ Hand Geometry for Door Access

- Shape of hand
- Reader is very large, so usually used for door access

5.5: Biometric Methods

■ Voice Recognition

- High error rates
- Easily deceived by recordings

■ Other Forms of Biometric Authentication

- Veins in the hand
- Keystroke recognition (pace in typing password)
- Signature recognition (hand-written signature)
- Gait (way the person walks) recognition

Biggest Problems of Biometric Methods

- Lost once, lost forever
 - You can not change your biometric features, unlike passwords
 - More and more devices are using biometric features
 - Lost once, lost forever!
- Governments or big companies have all your secrets
 - Your daily activities, your habits, your online posting.....
 - Privacy protection is very weak....

What's Next?

5.1 Introduction

5.2 Physical Access and Security

5.3 Passwords

5.4 Access Cards and Tokens

5.5 Biometric Authentication

5.6 Cryptographic Authentication

5.7 Authorization

5.8 Auditing

5.9 Central Authentication Servers

5.10 Directory Servers and Identity Management

5.8: Auditing

■ Auditing

- Authentication: Who a person is
- Authorization: What a person may do with a resource
- Auditing: What the person *actually did*

5.8: Auditing

■ Logging

- Events
- On a server, logins, failed login attempts, file deletions, and so forth
- Events are stored in a log file

5.8: Auditing

■ Log Reading

- Regular log reading is crucial or the log becomes a useless write-only memory
- Periodic external audits of log file entries and reading practices
- Automatic alerts for strong threats